

Phase 6 - Security Auditing & Cockpit

This document covers the final manual security audit pass performed on the system — SUID/SGID binary review, world-writable file scan, empty-password check, and account control re-verification — along with the setup and firewall-scoped exposure of the Cockpit web console.

1. SUID Binaries

A system-wide scan for SUID binaries (`find / -perm -4000`) was performed. SUID files run with the owner's privileges regardless of who executes them, making them a classic privilege-escalation vector if misconfigured. All 22 results below are standard RHEL system binaries expected on any default installation (`passwd`, `sudo`, `mount`, `crontab`, etc.) — no unexpected or third-party SUID binaries were found:

```
/usr/lib/polkit-1/polkit-agent-helper-1
/usr/bin/umount
/usr/bin/chage
/usr/bin/gpasswd
/usr/bin/newgrp
/usr/bin/passwd
/usr/bin/mount
/usr/bin/fusermount3
/usr/bin/su
/usr/bin/chfn
/usr/bin/chsh
/usr/bin/crontab
/usr/bin/pkexec
/usr/bin/sudo
/usr/bin/vmware-user-suid-wrapper
/usr/bin/at
/usr/sbin/pam_timestamp_check
/usr/sbin/unix_chkpwd
/usr/sbin/grub2-set-bootflag
/usr/sbin/mount.nfs
/usr/libexec/libgtop_server2
/usr/libexec/dbus-1/dbus-daemon-launch-helper
```

2. SGID Binaries

A parallel scan for SGID binaries (`find / -perm -2000`) was performed. Most results are again standard system utilities:

```
/usr/bin/write
/usr/bin/plocate
/usr/sbin/lockdev
/usr/sbin/postdrop
/usr/sbin/postlog
/usr/sbin/postqueue
/usr/libexec/utempter/utempter
```

One result stands apart from the rest of this list:

3. World-Writable Files

A scan for world-writable files outside virtual filesystems (`find / -xdev -type f -perm -0002`) returned no results — a clean pass with no unexpected write-permissive files found on the system.

4. Empty Password Check

Every account in `/etc/shadow` was checked for a blank password field. An empty result here is itself the expected "pass" condition — no accounts exist with no password set:

```
(empty result = no accounts with blank passwords - pass)
```

5. Account Lockout & Aging Re-Verification

As a final check, the password aging policy and lockout status configured in Phase 2 were re-verified across all five provisioned accounts, confirming the controls remained correctly in place:

```
== alaa ==
Last password change      : Jul 04, 2026
Password expires          : Oct 02, 2026
Password inactive         : Oct 16, 2026
alaa P 2026-07-04 1 90 7 14

== mostafa ==
Last password change      : Jul 03, 2026
Password expires          : Oct 01, 2026
Password inactive         : Oct 15, 2026
mostafa P 2026-07-03 1 90 7 14

== sara ==
Last password change      : Jul 03, 2026
Password expires          : Oct 01, 2026
Password inactive         : Oct 15, 2026
sara P 2026-07-03 1 90 7 14

== hassan ==
Last password change      : Jul 03, 2026
Password expires          : Oct 01, 2026
Password inactive         : Oct 15, 2026
hassan P 2026-07-03 1 90 7 14

== temp_contractor ==
Last password change      : Jul 03, 2026
Password expires          : never
Password inactive         : never
temp_contractor L 2026-07-03 0 99999 7 -1
```

Note: The four active accounts (alaa, mostafa, sara, hassan) all correctly carry the 90-day aging policy with a 7-day warning and 14-day inactive grace period. temp_contractor shows the "L" (locked) status with no expiry tracking needed, since the account is fully deactivated rather than subject to rotation.

6. Firewall Configuration for Cockpit

Cockpit access was scoped deliberately through firewalld rather than opening port 9090 broadly. The active public zone confirms cockpit is present alongside only ssh and dhcpv6-client — no unnecessary services exposed:

```
public (default, active)
  target: default
  interfaces: ens160
  services: cockpit dhcpv6-client ssh
  ports:
  forward: yes
  masquerade: no
```

7. Cockpit Service State

Cockpit was enabled via socket activation rather than running as a constant background process — the socket listens on port 9090 and only starts the full Cockpit service on demand when a browser actually connects:

```
● cockpit.socket - Cockpit Web Service Socket
   Loaded: loaded (/usr/lib/systemd/system/cockpit.socket; enabled; preset:
enabled)
   Active: active (running) since Sat 2026-07-04 20:51:45 EEST; 1h 0min ago
  Triggers: ● cockpit.service
   Listen: [::]:9090 (Stream)
    Tasks: 0 (limit: 10098)
   Memory: 144K (peak: 2.2M)
```

The dashboard was accessed via `https://<server-ip>:9090` and logged into using the alaa account, demonstrating role-based access through the same hardened account used throughout the project.

alias
servera.rhelproject.local

Q Search

System

Overview

Logs

Storage

Networking

Podman containers

Accounts

Services

Tools

Applications

alias
servera.rhelproject.local

Q Search

System

Overview

Logs

Storage

Networking

Podman containers

Accounts

Services

Tools

Applications

Diagnostic reports

Kernel dump

SELinux

Software updates

Limited accessHelpSession

Web console is running in limited access mode.

Turn on administrative access

servera.rhelproject.local running Red Hat Enterprise Linux 10.2 (Coughlan)

Health

Security updates available

Not connected to Insights

Last successful login: Jul 04, 06:22 PM
from 192.168.136.128 on jhu/1

View login history

Usage

CPU1% of 1 CPU

Memory1.3 / 1.6 GiB

View metrics and history

System information

ModelVMware, Inc. VMware28.1

Machine ID4cd8dced7b-443f991ab98abaf25418

Up since4 hours ago

View hardware details

Configuration

Hostnameservera.rhelproject.local

System timeJul 4, 2026, 9:48 PM

Domainjob.storm

Performance profilebalanced

Cryptographic policyDefault

Secure shell keysShow fingerprints

Groups4 users2 roles2 resources23 items...

Accounts

Q Search for name, group...

Username	Full name	ID	Last active	Group
alia	Syadmir - Alia	1005	Logged in	aliaadminalia
fatima		1001	Never logged in	fatima
hassan	Auditor - Hassan	1007	Never logged in	auditorhassan
laboulamjed	Laboulam Ahmed	1008	Logged in	laboulamjedlaboulamjed
mostafa	Developer - Mostafa	1006	Never logged in	devmostafamostafa
riyat		1004	Never logged in	phibonriyat
root	Super User	0	Jun 30, 2026, 9:25 AM	adminroot
sara	Developer - Sara	1002	Never logged in	devsarasara
youssef		1003	Never logged in	phibonyoussef